

Building an AI Governance Framework for Finance Teams

A self-directed project extending my MSc dissertation research

Mark Maxwell Louis

Why I built this

My dissertation looked at how AI is changing strategic decision-making in management accounting (Brunel University London, graded A-). One of the main findings was that AI tools only create real value in finance when they're backed by proper governance; otherwise, you just get faster mistakes instead of slower ones.

That finding stayed academic until I tried to turn it into something a finance team could use. This is that attempt: a practical governance framework for finance/BI teams who are adopting AI tools (forecasting, automated reporting, anomaly detection) but don't yet have a dedicated AI risk function, which, from what I've read, describes most small and mid-size finance teams right now.

I want to be upfront that I built this independently, not inside an organisation, so it hasn't been pressure-tested against a real deployment. What it does show is that I can take regulatory frameworks (EU AI Act, NIST, ISO 42001) and turn them into something usable, not just summarise them.

What I used

I anchored this on three frameworks rather than inventing my own:

- **NIST AI Risk Management Framework** — gave me the structure (Govern / Map / Measure / Manage) for organising controls
- **ISO/IEC 42001** — the new AI management system standard, useful for showing what a certifiable AI governance setup actually looks like
- **EU AI Act risk tiers** — this one needed care, because the deadlines kept moving. The original August 2026 deadline for high-risk systems got pushed to December 2027 after a political agreement reached in May 2026, so I checked the current timeline before writing this rather than relying on older sources, which would have been wrong by the time anyone reads this.

I leaned on the structural stuff (risk classification, human sign-off, vendor checks, documentation) rather than the specific dates, because those are the parts that stay true regardless of which deadline is live when this gets read.

The risk areas I focused on

Rather than trying to cover every possible AI risk, I picked the ones that actually show up in a finance/BI context, because that's the area I know:

- **Model risk** — forecasting tools being confidently wrong (e.g. trained on data that doesn't reflect a recent shock)
- **Data risk** — feeding stale or biased data into a model without realising
- **Explainability** — not being able to explain why an AI tool flagged something, which is a real problem if a regulator or auditor asks
- **Vendor risk** — most finance teams aren't buying "an AI model," they're buying a BI tool that has AI features bolted on, and most people don't check what that actually means
- **Automation bias** — the human stops checking the AI's work, which defeats the point of having a human in the loop at all
- **Operational resilience** — what happens to the month-end close if the AI tool you've started relying on goes down

This list isn't exhaustive — there are other categories (security, IP/copyright on training data, etc.) I didn't cover because they're less specific to finance functions, and I wanted this to stay focused rather than turn into a generic AI risk catalogue.

A simple maturity model

I used a 5-level scale, similar to the maturity model I built for the Ceres Power commercial readiness project during my MSC:

Level	What it looks like
1 — Ad hoc	People using AI tools individually, no one tracking it
2 — Aware	Leadership knows AI is being used, but there's no policy yet
3 — Managed	There's an inventory of AI tools and a basic risk classification
4 — Integrated	A governance group exists, vendor checks happen, staff get some training
5 — Optimised	Ongoing monitoring, reporting to leadership, the governance process itself gets reviewed

My honest assessment is that most finance teams using AI informally (an Excel AI add-in here, an LLM-assisted report there) are sitting at level 1 or 2 without realising it. This framework is aimed at getting a team from there to level 3 or 4 — I don't think level 5 is realistic without a dedicated risk team, so I didn't pretend otherwise.

What the controls actually look like

Mapped loosely to the NIST functions, but kept practical rather than theoretical:

NIST function	What it means in practice
Govern	Someone owns this. Not "everyone," one named person or small group.
Map	Know which AI tools you're actually using — most teams underestimate this
Measure	Check the AI's output against something else occasionally, don't just trust it
Manage	Have a plan for when it gets something wrong, and a way to flag it

A worked example (illustrative, not from a real engagement)

AI tool	Risk level	Main risk	What I'd put in place
AI-written variance commentary	Limited	Analyst stops double-checking it	Require sign-off against the source ledger before it goes external
BI tool with an AI forecasting feature	Limited	No one knows when the vendor changes the model	Ask the vendor directly, in writing, to flag model changes
Customer churn scoring (if used for pricing decisions)	Higher	Can't explain why a customer scored badly	Add basic feature-importance reporting so a human can sanity-check it

Roughly how I'd roll this out

I split this into three stages, mostly because "do everything at once" isn't realistic for a team with no existing AI governance:

- **Months 0–3:** Just find out what AI tools are actually in use. This sounds basic, but most teams don't have this list.
- **Months 3–6:** Add the sign-off and vendor-check controls. This is the unglamorous part that actually matters.
- **Months 6–12:** Start checking model performance occasionally and report to leadership.

What I'd do differently / limitations

This was built as a self-study project, not inside a real company, so a few honest caveats:

- I haven't tested this against an actual messy AI deployment, real organisations will have edge cases this doesn't cover

- The regulatory references (especially EU AI Act dates) will need rechecking by the time anyone reads this, given how often the timeline has shifted
- I focused on finance/BI use cases specifically because that's where my dissertation and experience sit this isn't meant to be a general-purpose AI governance framework

Why this matters to me

I did my MSc dissertation on AI in management accounting because I think this is where finance is heading, but the academic side of it stops short of being usable. This project was my attempt to close that gap — take the research finding (governance maturity matters more than the technology) and turn it into something with actual structure: a maturity model, a control list, a rollout plan. It's the difference between writing about AI governance and actually starting to build it for a team.